

TRAINING @ FORREST ONE

Session 7 of 12

Network Fundamentals + CompTIA Security+ SY0-701

Security Architecture & Data Protection

Where systems run, how they are designed, and how their data is protected in every state it occupies.

LESSON 4

ARCHITECTURE

DATA

RESILIENCE

© Billy Forrest



WELCOME · WHERE WE ARE

The shape of the session

- **Session 6** gave us cryptography, the mechanisms of protection
- **Today** architecture: where systems run and who carries the risk
- **Chapters 1 to 2** architecture models, then compute and edge platforms
- **Chapter 3** secure design: code, network patterns and control selection
- **Chapter 4** the data itself: types, states, classification and encryption
- **Chapters 5 to 6** resilience, recovery objectives and business continuity
- **The thread** every control protects data or the systems that hold it

Architecture decisions are long lived. A mistake here can persist for years, and no amount of patching afterwards will fully undo it.



SESSION OBJECTIVES

By the end of this session you will be able to

- **Compare architecture models** on premises, public, private, hybrid and community cloud
- **Place the responsibility line** IaaS, PaaS and SaaS, and what you still own at each
- **Secure compute platforms** the hypervisor, container images, serverless triggers
- **Reason about edge and industrial systems** IoT risk, SCADA, and IT and OT convergence
- **Design for containment** infrastructure as code, defence in depth, segmentation
- **Protect data by type and state** classification, at rest, in transit, and disposal
- **Build in resilience** redundancy, alternate sites, backups, recovery objectives
- **Plan for continuity** business impact analysis and rehearsed recovery



CHAPTER 1 · ARCHITECTURE MODELS

On-Premises Architecture

- **What it is** the organisation owns the hardware and can physically touch it
- **The advantage** direct physical control: server room access regulated and recorded, possibly biometric
- **The price** patching, maintenance, disaster recovery planning and skilled staff all sit with you
- **Total cost of ownership** capital purchase, plus power, cooling, upgrades and replacement
- **Still appropriate for** regulated industries, classified data and very low latency workloads
- **The trade** control and responsibility are the same coin

On premises buys you control and charges you for it. Every capability you keep in house is a capability you must staff and maintain.



CHAPTER 1 · ARCHITECTURE MODELS

Cloud Deployment Models

Model	Who shares it	Security responsibility
Public	Shared among tenants, sold by providers	Provider secures the infrastructure, customer secures the data
Private	Dedicated to one organisation, on premises or hosted	Customer takes most of the responsibility
Hybrid	A mix of public and private, joined together	Shared, and the customer secures the transfer between them
Community	Several organisations with common needs	Shared policies agreed between the members

Cloud changes the question to who shares the platform. Each model shifts the security duties between the provider and the customer, so the first job is to find where that line falls.



CHAPTER 1 · ARCHITECTURE MODELS

Cloud Service Models

- **Infrastructure as a Service** virtual machines, storage and networks; you secure everything above the hypervisor
- **Platform as a Service** a managed runtime; your work is application security and data protection
- **Software as a Service** the whole stack is managed; you manage access and protect the data inside
- **The pattern** the more the provider manages, the less you control and the less you carry
- **Named examples** AWS, Microsoft Azure and Google Cloud Platform for public cloud

Know where the line falls, and you know what you own.



QUIZ

Activity: read the responsibility line

- You rent a virtual machine and patch its operating system yourself. Which model?
- You deploy application code onto a managed runtime and never touch an operating system. Which model?
- You use a hosted mail suite and manage only permissions and data. Which model?
- Where does the line sit in each case, and what are you still responsible for?

Test the model with cases, not definitions: the boundary moves, and your job is to know where it sits.



CHAPTER 2 · COMPUTE AND EDGE PLATFORMS

Compute and Edge Platforms

- **Virtualisation** many virtual machines on one host, and the hypervisor beneath them
- **Containers** a lighter boundary: a shared kernel and a packaged image
- **Serverless** the provider runs the infrastructure, you write the functions
- **The internet of things** devices that were never designed to be defended
- **Industrial control** the systems that keep power and water flowing

In every case the patch responsibility moves to somebody else, and that changes the risk as much as the technology does. Ask who applies the patches and the architecture explains itself.



Virtualisation Security

- **Type 1 hypervisor** runs directly on the hardware, so a smaller attack surface
- **Type 2 hypervisor** runs on a host operating system, so a flaw there affects every guest
- **Virtual machine escape** breaking out of a guest to reach the hypervisor
- **Sprawl** forgotten virtual machines that are never patched
- **Snapshots** hold sensitive data and consume storage
- **Resource isolation** limits one guest affecting another
- **The foundation** the hypervisor is the highest value target

Everything the guests do depends on the hypervisor, so it is patched first and monitored hardest.



CHAPTER 2 · COMPUTE AND EDGE PLATFORMS

Containerisation

- **Shared kernel** no full operating system per instance, so it is lighter than a virtual machine
- **The image** packages the code with its libraries and configuration
- **Consistency** the same image behaves the same everywhere, which is why Docker spread fast
- **The risk** a vulnerable library inside the image is reproduced in every copy
- **Scan and trust** scan images and pull them from trusted sources
- **Orchestration** platforms such as Kubernetes need their own controls

Containers are the same idea as virtualisation with a smaller boundary. The boundary is smaller, not absent.



CHAPTER 2 · COMPUTE AND EDGE PLATFORMS

Serverless Architecture

- **The model** the provider runs the infrastructure; you write functions
- **Event driven** a function executes only when something triggers it
- **Stateless and ephemeral** it lives just for the execution, which shrinks the attack surface
- **Examples** Amazon Lambda, Azure Functions and Google Cloud Functions
- **The catch** the trigger is an entry point, so authenticate and validate every event
- **Blind spot** less visibility inside the provider platform

You trade control for less to manage. What you cannot see, you cannot monitor, so lean on provider logging.



Internet of Things Security

- **Too small** limited processing power, so heavy security controls will not fit
- **Rarely updated** infrequent updates leave known flaws open for a long time
- **Default credentials** shipped with them, and nobody ever changes them
- **Huge scale** the sheer number means every device is another way in
- **Segment** keep devices away from critical systems
- **Monitor** continuous anomaly monitoring, and lifecycle management to decommissioning

Cheap devices, weak defences, and enormous numbers. You cannot patch your way out, so you segment and watch.



CHAPTER 2 · COMPUTE AND EDGE PLATFORMS

Industrial Control Systems and SCADA

Component or term	What it does
Industrial control systems (ICS)	Distributed control systems and programmable logic controllers
SCADA	Supervisory Control and Data Acquisition, the control overlay
Field devices and terminal units	Collect data and run commands in the plant
Human machine interface	Gives the operators their view of the process
Legacy protocols	No encryption and no authentication built in

Safety and availability outrank confidentiality here. Stopping a pump or a turbine can be dangerous, so a breach can damage equipment or hurt people.



DISCUSSION

IT protects confidentiality. OT protects safety. What happens when you join the two networks?

Efficiency is the reason, and the attack surface is the cost. Once the networks are joined, an intruder who reaches the office can reach the plant. The answer is not to keep them apart forever, but to segment deliberately, place monitoring that understands industrial protocols, and test the result before you rely on it.

Information technology and operational technology protect different things, and they think differently. Convergence is a design decision, not an accident.



CHAPTER 3 · SECURE DESIGN

Secure Design

- **Infrastructure as code** machines configured from version controlled files
- **Secure network design** the patterns that contain an intruder
- **Control selection** how to choose a control and justify the choice
- **Why it matters** design decisions last for years, so they are worth getting right

A network built without thought about containment is a network where one stolen laptop becomes an estate wide incident. Get the design right and everything after it is easier.



CHAPTER 3 · SECURE DESIGN

Infrastructure as Code

- **The idea** machine readable files replace manual setup by hand
- **Repeatable** the same file builds the same server every time
- **Version control** a history of every change, and rollback to a known good state
- **Automated checking** scanning catches a weak setting before it reaches production
- **The benefit** consistency, and consistency is where most security actually comes from

Consistency is a security control in its own right, because drift is where undocumented weaknesses live.



CHAPTER 3 · SECURE DESIGN

Infrastructure as Code Risks

- **Misconfiguration at scale** one error in the file is reproduced in every environment that uses it
- **Secrets in the file** keys and passwords written into configuration leak through repositories
- **Use a secrets manager** dedicated storage for secrets, never the configuration file
- **Peer review** review every change before it deploys
- **Validate in the pipeline** and isolate development, test and production environments
- **Audit and test** penetration test the configurations as you would any system

The same power that builds at speed can break at speed.



CHAPTER 3 · SECURE DESIGN

Secure Network Design

- **Defence in depth** layers of control, so one failure is not fatal
- **Segmentation** virtual local area networks, with firewalls between them
- **Access control lists** state which segment may talk to which
- **Demilitarised zone** a buffer segment for services that face the public
- **Least connectivity** allow only the connections the business truly needs
- **The purpose** segmentation turns one breach into one contained breach

Layers buy you time, and containment buys you scope. Both are design decisions made before the incident, not during it.



CHAPTER 3 · SECURE DESIGN

Protecting the Channel

Technology	What it does
Virtual private network	Encrypts traffic across an untrusted network
Transport Layer Security	Secures web traffic; the handshake authenticates and agrees keys
Internet Protocol Security	Network layer encryption, tunnel mode for VPNs
Jump server or bastion host	A controlled entry point for administrators, never direct access
Certificate management	Issue, renew and revoke through a trusted authority

Once data leaves a trusted segment you must protect it in transit. A stolen administrator session is as damaging as a stolen password.



CHAPTER 3 · SECURE DESIGN

Security Control Selection

- **Risk assessment** the results set the priority and tell you which threat deserves the budget
- **Compliance** some requirements dictate controls outright, such as encrypting cardholder data
- **Cost** the purchase cost and the ongoing cost of running the control
- **Operational impact** a control that blocks the business will simply be bypassed
- **Three categories** technical, administrative and physical controls working together
- **Then test and monitor** and watch it through a Security Information and Event Management system

Control selection is a decision, not a shopping list. Confidentiality, integrity and availability guide every choice.



CHAPTER 4 · DATA PROTECTION

Data Protection

- **Data types** the categories that carry legal weight
- **Data states** at rest, in transit, and in use
- **Classification** the label that decides how data is handled
- **Protection** encryption at rest and in transit, and secure disposal

You cannot defend what you have not identified. Identify the data and label it first, because type sets the legal obligation and state sets the control you need.



CHAPTER 4 · DATA PROTECTION

Data Types and States

- **Personally identifiable information** names, addresses and identifiers; exposure enables identity theft
- **Protected health information** medical records covered by health privacy law
- **Financial data** card numbers and account details, under the payment card industry standard
- **Data at rest** stored on media, drives and databases
- **Data in transit** moving across a network
- **Data in use** being processed in memory
- **The rule** each state has its own protection

Type sets the obligation. State sets the control.



CHAPTER 4 · DATA PROTECTION

Classification Levels

Level	Typical content	Handling
Public	Press releases, marketing material	No special protection
Internal	Memos, handbooks, project reports	Not for public release
Confidential	Personal information, customer data	Encrypt and restrict access
Restricted	Trade secrets, classified material	Highest protection, need to know only

Classification tells you how much protection data deserves. You cannot protect what you have not labelled.



CHAPTER 4 · DATA PROTECTION

Classification Drives Handling

- **Storage** restricted data encrypted with tight access control; public data needs nothing special
- **Transmission** confidential and restricted data encrypted and sent over trusted channels
- **Disposal** secure wipe or physical destruction: a drive sold with restricted data is a breach
- **Label it** physically or as metadata, so users know what they are holding
- **Train people** until classification becomes habit rather than paperwork
- **Review the policy** as the business changes

Classification only earns its keep when it changes behaviour. A label nobody reads is decoration.



CHAPTER 4 · DATA PROTECTION

Protecting Data at Rest

- **Full disk encryption** protects everything on the drive, which is what a stolen laptop needs
- **Examples** BitLocker on Windows, FileVault on macOS
- **File level encryption** selected files and directories; Encrypting File System on Windows
- **Database encryption** whole tablespaces, or single sensitive columns
- **Key management** generate keys securely, store them safely, rotate them, restrict their use
- **Hardware security module** holds keys in tamper resistant hardware

Encryption is only as strong as the key handling behind it.



CHAPTER 4 · DATA PROTECTION

Secure Disposal and Physical Protection

- **Wiping** overwrites the data so it cannot be recovered, on hard disk drives and solid state drives
- **Degaussing** a strong magnet: destroys magnetic media, and does nothing useful to solid state drives
- **Destruction** shredding, crushing or incineration, the right answer for highly sensitive media
- **Physical access control** on server rooms and media stores
- **Environmental protection** against fire, flood and heat
- **Pair them** encryption plus physical control, never one alone

The end of a device life is still part of its security. Disposal is where good intentions leak.



CHAPTER 4 · DATA PROTECTION

Protecting Data in Transit

- **Use the secure version** of every protocol you already know
- **Web and files** Hypertext Transfer Protocol Secure for web, Secure File Transfer Protocol for files
- **Mail** Simple Mail Transfer Protocol Secure, and Pretty Good Privacy for message content
- **Data loss prevention** watches outbound traffic and blocks sensitive content from leaving
- **Validate certificates** signature, expiry and revocation status
- **The rule** never assume the network is safe, because sometimes it is not

Accepting a certificate warning is exactly how an attacker in the middle succeeds.



CHAPTER 5 · RESILIENCE AND RECOVERY

Resilience and Recovery

- **Availability** redundancy in layers, and the removal of single points of failure
- **Alternate sites** hot, warm and cold, and the geography that suits them
- **Backup and recovery** the strategies, and the objectives that drive the design
- **Facilities** power, environment and platform diversity
- **Testing** because an untested plan is only a guess

Resilience is a design habit, built from redundancy, planning and rehearsal. A service that has never been failed over on purpose is a service nobody really understands.



CHAPTER 5 · RESILIENCE AND RECOVERY

High Availability Concepts

- **Measured** uptime percentage and mean time between failures
- **RAID** a redundant array of independent disks, mirrored for fault tolerance
- **Teamed network cards** for redundancy and extra bandwidth
- **Clustered servers** take over from each other
- **Load balancing** spreads traffic and checks health before sending work
- **Failover** moves control to a standby system; automatic beats a human with a phone
- **The aim** remove single points of failure, including power supplies and switches

Availability is designed, not hoped for.



CHAPTER 5 · RESILIENCE AND RECOVERY

Alternate Sites and Geography

Site	Readiness	Relative cost
Hot	Fully equipped with current data, immediate failover	Highest
Warm	Hardware in place, data must be restored and systems configured	Moderate
Cold	Power and cooling only, an empty shell	Lowest

Geography is the balancing act: far enough apart that one flood cannot take both sites, close enough that replication stays acceptable.



CHAPTER 5 · RESILIENCE AND RECOVERY

Backup Strategies and Recovery Objectives

Strategy or objective	What it means
Full backup	Copies everything: simplest restore, largest and slowest
Incremental	Changes since the last backup of any kind; restore needs the full plus every increment
Differential	Everything since the last full backup; restores faster than incremental
Recovery Point Objective	How much data the business can afford to lose
Recovery Time Objective	How long the service can be unavailable

Backups are the last line of defence, and the recovery objective comes first. Design the backup to meet the objective, not the other way round.



CHAPTER 5 · RESILIENCE AND RECOVERY

Power, Environment and Platform Diversity

- **Uninterruptible power supply** carries the load through a short outage
- **Generators** cover a long outage, and are used together with the UPS
- **Cooling** prevents overheating and hardware failure
- **Fire suppression** protects the equipment
- **Humidity control** stops static discharge and condensation
- **Platform diversity** different technologies, more than one vendor
- **The payoff** a single flaw or one supplier failing cannot take everything down at once

Do not put every system on one platform. Diversity is cheap insurance.



CHAPTER 5 · RESILIENCE AND RECOVERY

Testing Resilience and Recovery

- **Tabletop exercise** a discussion that finds gaps in plans, roles and communication
- **Simulation testing** runs the components under stress and modelled failure
- **Full failover testing** shuts the primary down on purpose and proves the backup carries the load
- **Parallel processing** validates recovery alongside production, without disruption
- **Document it** the scenarios, the actions and the lessons learned
- **Repeat it** test regularly, because systems and threats both change

An untested plan is only a guess. The lessons learned are the real output of a test.



BREAK
10 MINUTES

Back soon: business continuity planning, the exam map, and the quiz.



CHAPTER 6 · CONSOLIDATION

Consolidation

- **Business continuity planning** the umbrella that holds recovery and resilience together
- **Where decisions land** a technical choice becomes a business commitment
- **The test of a plan** whether it is rehearsed, or quietly abandoned
- **What follows** the exam map, the quiz, and your revision checklist

Continuity is not a document that lives in a drawer. It is a set of rehearsed actions owned by named people.



CHAPTER 6 · CONSOLIDATION

Business Continuity Planning

- **Business impact analysis** identifies the critical processes and their dependencies
- **Acceptable downtime** set it for each critical process, using the recovery objectives
- **Continuity of operations** keeps those functions running from an alternative arrangement
- **IT disaster recovery** the part that restores systems and data
- **The plan is never finished** update it when the business changes
- **Rehearse it** train with the people who will have to use it

Continuity is a business plan with IT inside it.



EXAM ALIGNMENT

What this maps to in the exam

Objective	What the exam tests
Architecture models	On premises, cloud deployment and service models, shared responsibility
Compute and edge	Hypervisor types, virtual machine escape, containers, serverless, IoT, ICS and SCADA
Secure design	Infrastructure as code, defence in depth, segmentation, control selection
Data protection	Data types and states, classification, encryption at rest and in transit, disposal
Resilience	High availability, alternate sites, backup strategies, RPO and RTO, continuity

Architecture and data protection questions appear across multiple domains. Expect scenarios that ask where the responsibility line sits, and which control fits the data state.



QUIZ

Check your understanding

- Open Quiz_Session_07.html in your browser.
- 20 questions, immediate feedback, and a domain and area tag on every question.
- Read each explanation: the distractors teach as much as the answer.
- Score 70% or better before moving on.

Every question is tagged with the syllabus domain and area it tests.



KEY TAKEAWAYS

- **Architecture sets where the trust sits** know the shared responsibility line, and secure the hypervisor.
- **Compute models move the boundary** virtualisation, containers and serverless shrink what you manage, not what you must secure.
- **Edge and industrial systems need discipline** segmentation, monitoring and lifecycle management to decommissioning.
- **Infrastructure as code cuts both ways** it gives consistency, and misconfiguration at scale. Keep secrets out of the file.
- **Classification decides handling** type sets the obligation, state sets the control, and labels make it real.
- **Resilience is built and tested** redundancy, recovery objectives, and plans you have actually rehearsed.



REVISION CHECKLIST

Before next session

- **Retake the quiz** until you score 70% or better without guessing
- **Find the line** pick one cloud service you use, and write down what you still own in it
- **Classify something real** choose a dataset at work and assign it a classification level
- **Name your recovery objectives** what are the RPO and RTO for your most critical system?
- **Read ahead** Session 8: network security controls and segmentation



NEXT SESSION

Session 8 — Network Security Controls & Segmentation

- Physical security and deception technologies
- Audits, regulatory compliance and key management
- Segmentation for special environments, guests and BYOD
- Device hardening, network access control and filtering

